

MFA & Security Best Practices

BaseStack Academy · AWS Cloud Accelerator

IAM & Security

Cohort 1

Beginner-Friendly

SAA-C03 Aligned

Factor 1

Password (Something you KNOW)

Factor 2

TOTP Code (Something you HAVE)

Factor 3

Hardware Key (Physical token)

 **MFA: Your last line of defence**

1 Overview — Why Identity Is Your Largest Attack Surface

FOUNDATION

2 MFA Types — Virtual, Hardware, FIDO2 & When to Use Each

CORE KNOWLEDGE

3 IAM Security Best Practices — Root, Keys & Policies

DEEPER LEARNING

4 How It Works — Enforcing MFA with IAM Policies

MECHANICS

5 Technical Deep Dive — Permission Boundaries & Access Analyzer

ADVANCED DETAIL

6 Architecture & Visual Model — Layered Security

VISUAL

7 Real-World Nigerian Scenario

CONTEXT

8 Common Mistakes & Exam Traps

EXAM PREP

Overview — Why Identity Is Your Largest Attack Surface

In the cloud, your perimeter is not a firewall — it is an identity. There are no physical walls between the internet and your AWS infrastructure. The only thing standing between an attacker and your EC2 instances, your S3 buckets, your databases, and your customer data is a set of credentials: a username, a password, and ideally a second factor of authentication.

When those credentials are compromised — through phishing, credential stuffing, leaked access keys in a public GitHub repository, or a brute-force attack on a weak password — everything that identity has access to is immediately accessible to the attacker. No alarm goes off. No door rattles. They walk straight in.

According to the Verizon Data Breach Investigations Report, over 80% of hacking-related breaches involve compromised credentials. Multi-Factor Authentication (MFA) is the single most effective control against credential-based attacks — it reduces account compromise risk by over 99% when properly enforced.

WHY NOW?

In 2023, multiple Nigerian fintech accounts were compromised through phishing attacks targeting staff with excessive IAM permissions. The breaches were not due to AWS infrastructure vulnerabilities — they were due to stolen credentials and absent MFA enforcement.

The CBN Cybersecurity Framework requires multi-factor authentication for all privileged system access. NDPC (Nigeria Data Protection Commission) data breach notification obligations make credential security a legal risk, not just a technical one.

SAA-C03 Domain 2 directly tests IAM security controls including MFA enforcement, least-privilege policies, and credential management.

Beginner Note

Think of MFA like the dual-key system that Nigerian banks use for the bank manager's safe — two separate keys, held by two different people, both required to open it. One stolen key alone cannot open anything. MFA does the same for your AWS account.

MFA Types — Devices, Standards & When to Use Each

Not all MFA is equal. Understanding the differences — strength, cost, usability — is essential for designing the right MFA policy for each user population in your organisation.

Virtual MFA Device

Authenticator App (TOTP)

✅ Available to all IAM users — free, no hardware required

A Time-Based One-Time Password (TOTP) generated by an app: Google Authenticator, Authy, Microsoft Authenticator, or any RFC 6238-compliant app.

How it works: The app shares a secret key with AWS at setup. Every 30 seconds, both AWS and the app independently generate the same 6-digit code using that key + the current timestamp. The code is valid for 30 seconds then changes.

Strength: Good. Resistant to password spraying. Vulnerable to real-time phishing (attacker intercepts the code live) but impractical for most attackers.

📄 SAA-C03: Virtual MFA is the default recommendation for standard IAM users. Set up: IAM → Users → Security Credentials → Assign MFA device.

Hardware MFA Token (TOTP)

Physical TOTP Device — e.g., Gemalto token

⚠️ Requires physical device purchase and distribution

A dedicated physical device that generates TOTP codes — identical algorithm to virtual MFA but on dedicated hardware rather than a smartphone.

Advantage over virtual: Cannot be compromised by smartphone malware. Smartphone theft with an unlocked authenticator app gives both factors to an attacker. A hardware token is a separate, dedicated device.

Best for: Administrators, finance teams, root account holders — any user whose compromise would have severe business impact. Required by many financial regulators for privileged access.

📄 SAA-C03: Hardware MFA devices are more secure than virtual MFA apps — they cannot be cloned or copied from a screenshot.

FIDO2 / WebAuthn Security Key

Passkey Standard — e.g., YubiKey, Google Titan

✅✅ Strongest available — phishing-resistant by cryptographic design

FIDO2 (Fast Identity Online 2) uses public-key cryptography instead of shared secrets. The security key generates a key pair per site. The private key never leaves the device. Authentication requires physical possession of the key AND interaction (pressing a button).

Phishing-resistant by design: Even if an attacker tricks you into authenticating on a fake site, the FIDO2 key refuses — it cryptographically verifies the site's origin and will not sign a request for a different domain.

Best for: Root account, security team, executives, CI/CD pipeline service accounts.

📄 SAA-C03: FIDO2 / WebAuthn security keys are the strongest MFA option — they are phishing-resistant unlike TOTP, which can be intercepted.



IAM Security Best Practices — The 8 Rules

These are the AWS-recommended IAM security controls. Each one reduces a specific, documented attack vector. Know all eight for real work and for the exam.

1 Lock down the root account immediately

The root account has unrestricted access to everything — it cannot be limited by SCPs or IAM policies. Enable MFA on the root account before anything else. Then store the root password in a secrets vault (not your personal password manager). Never create access keys for root. Never use root for daily work — create an IAM admin user instead.

2 Never create root access keys

Root access keys cannot be scoped, rotated to a specific role, or restricted by any policy. If they leak, your entire account is compromised with no recovery path. AWS explicitly warns against root access keys in every security framework. If your account has existing root access keys — delete them now.

3 Enable MFA for all human IAM users

Every human user — not just admins — should have MFA enforced. Use an IAM policy with a condition key `aws:MultiFactorAuthPresent: false` to deny all actions if MFA was not used at login. This forces MFA without revoking the user's existing permissions.

4 Apply Principle of Least Privilege to every identity

Grant only the minimum permissions required for a task. Start with zero and add permissions as needed — never start with broad permissions and try to restrict later. Use IAM Access Advisor to identify permissions granted but not used in the last 90 days. Remove them.

5 Use IAM roles instead of long-term access keys

Access keys are static, long-lived credentials that can be accidentally committed to code repositories. IAM roles issue temporary credentials (via STS) that expire automatically. For EC2, Lambda, and ECS workloads — always use instance roles and execution roles, never hardcoded access keys.

6 Rotate access keys every 90 days — and audit with IAM Credential Report

If access keys must be used, rotate them regularly. The IAM Credential Report (a CSV you download from the IAM console) shows every user, their access key age, last used date, and MFA status. Run this report in your monthly security review. Keys unused for 90 days should be disabled.

7 Use Permission Boundaries to delegate safely

When you allow a team to create their own IAM roles (e.g., a dev team creating Lambda execution roles), use Permission Boundaries to set a hard ceiling on what those roles can include. The boundary prevents privilege escalation — a developer cannot create a role with more permissions than their own boundary allows.

8 Use IAM Access Analyzer to detect unintended external access

IAM Access Analyzer continuously evaluates your S3 bucket policies, IAM roles, KMS keys, SQS queues, and Lambda functions to identify resources accessible from outside your account or organisation. If a bucket policy accidentally allows public access, Access Analyzer flags it within minutes.



How It Works — Enforcing MFA with IAM Policies

1

Enable MFA on the IAM User or Root Account

In the IAM console, navigate to Users → select the user → Security Credentials tab → Assign MFA Device. Choose the device type: virtual (app), hardware token, or FIDO2 security key. For virtual MFA, scan the QR code with your authenticator app and enter two consecutive TOTP codes to confirm synchronisation. For root: sign in as root → Account Settings → Enable MFA. For FIDO2: insert the security key, press the button when prompted, registration is complete.

2

Write an IAM Policy That Enforces MFA at Authentication

Creating the MFA device is not enough. You must also write a policy that DENIES actions if the user authenticated without MFA. The condition key is `aws:MultiFactorAuthPresent`. Set Effect: Deny, Action: *, Resource: *, Condition: `BoolIfExists aws:MultiFactorAuthPresent = false`. Attach this policy to the user or group. Now any session started without MFA is locked out — the user sees `AccessDenied` on every action until they re-authenticate with MFA. Note: exclude `iam:CreateVirtualMFADevice` and `iam:EnableMFADevice` from the Deny to allow users to set up their own MFA.

3

Validate with IAM Credential Report & Access Advisor

After deploying MFA enforcement, run the IAM Credential Report to confirm coverage. The report shows `mfa_active: true/false` for every user. Filter for `mfa_active = false` — those users are not yet covered. For permissions auditing: use IAM Access Advisor (per-user view) to see the last time each permission set was used. Services not accessed in 90+ days should have those permissions removed. This is how you implement least-privilege iteratively — observe, reduce, repeat.

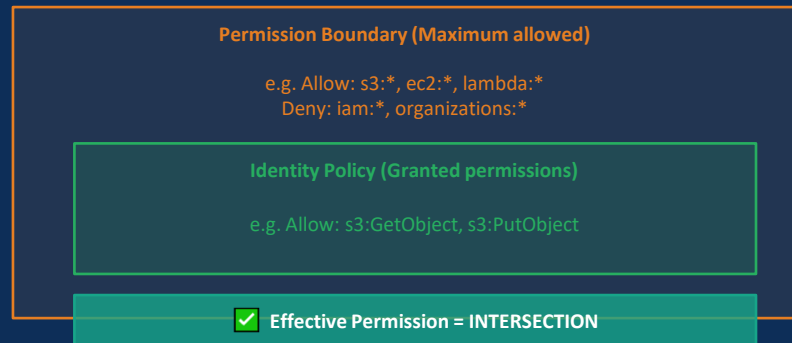


Technical Deep Dive — MFA Policy JSON & Permission Boundaries

MFA Enforcement IAM Policy (JSON)

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyWithoutMFA",
      "Effect": "Deny",
      "NotAction": [
        "iam:CreateVirtualMFADevice",
        "iam:EnableMFADevice",
        "iam:GetUser",
        "sts:GetSessionToken"
      ],
      "Resource": "*",
      "Condition": {
        "BoolIfExists": {
          "aws:MultiFactorAuthPresent":
            "false"
        }
      }
    }
  ]
}
```

Permission Boundaries — Delegation Without Escalation



Use case:

A dev team needs to create Lambda execution roles. You attach a Permission Boundary that limits those roles to S3 and DynamoDB only. The devs can create any role they want — but none of those roles can exceed the boundary's permissions.

Key rule:

Even if the identity policy grants `iam:*` — if the Permission Boundary does not include `iam:*`, IAM actions are DENIED. Boundary wins.

Exam trap:

Permission Boundaries do NOT grant permissions by themselves. The identity policy must ALSO allow an action for it to be permitted.



Key Concepts — Access Analyzer, Credential Report & Access Advisor



Three tools that operationalise least-privilege — know what each does, when to use it, and how they differ.



IAM Access Analyzer

Use when: you need to detect external access to your resources

WHAT: Continuously monitors resource-based policies (S3 buckets, IAM roles, KMS keys, Lambda functions, SQS queues, Secrets Manager secrets) and flags any resource accessible from outside your account or AWS organisation.

HOW: Enable in the IAM console → Access Analyzer → Create Analyzer (scope: account or organisation). Findings appear within minutes. Each finding shows: which resource, which external principal, which actions are permitted. You resolve findings by either confirming the access is intended (archiving) or fixing the policy.



SAA-C03: Access Analyzer = detect EXTERNAL resource access. It generates findings for resources reachable from outside your trust zone.



IAM Credential Report

Use when: you need a compliance audit of all user credentials

WHAT: A CSV report downloadable from the IAM console that lists every IAM user in the account and their credential status: password age, password last used, access key 1 and 2 age, last used, rotation date, and whether MFA is active.

HOW: IAM console → Credential Report → Download. Automate generation via: `aws iam generate-credential-report` then `aws iam get-credential-report`. Filter for: `mfa_active=false` (unenrolled users), `password_last_used > 90` days (inactive accounts), `access_key_1_last_used_date > 90` days (stale keys). These are your remediation targets.



SAA-C03: Credential Report = per-account compliance snapshot. It shows MFA status, key ages, and last-used dates for all users.



IAM Access Advisor

Use when: you need to see which permissions are actually being used

WHAT: A per-user/per-role view showing the last time each AWS service was accessed. Available in the IAM console under a user or role's 'Access Advisor' tab. Shows last access date per AWS service.

HOW: Navigate to IAM → Users or Roles → select entity → Access Advisor tab. Any service showing 'Not accessed in 90 days' is a candidate for permission removal. Use this iteratively: grant broad permissions initially if unsure, then observe for 30-90 days, then remove the unused ones. This is the systematic path to least privilege.



SAA-C03: Access Advisor = per-user service usage history. Used to identify and remove unused permissions — the operational tool for least privilege.



Architecture — Layered Identity Security Model

Defence in depth: each layer assumes the one above it can be breached. Together they create a security posture that is resilient against the most common cloud attack vectors.

Layer 1: Root Account Hardening

MFA enabled (FIDO2 recommended) · Root access keys DELETED · Root password in vault · Root never used for daily operations · Billing alerts on root

Protects against: total account takeover

Layer 2: MFA Enforcement (All Users)

Virtual MFA for standard users · Hardware MFA for admins · IAM policy with `aws:MultiFactorAuthPresent = false Deny` · SCP blocking MFA device deletion at org level

Protects against: stolen password attacks (phishing, credential stuffing, brute force)

Layer 3: Least Privilege + Permission Boundaries

IAM Access Advisor quarterly reviews · Credential Report monthly audit · Permission Boundaries on delegated role creation · SCPs restrict maximum permissions at OU level

Protects against: privilege escalation, blast radius expansion after compromise

Layer 4: Continuous Monitoring & Detection

IAM Access Analyzer: external resource access findings · CloudTrail (Day 4): all API activity logged · CloudWatch Alarms: root login, IAM changes, MFA disable · GuardDuty: anomalous credential usage detection

Protects against: undetected persistence, lateral movement, data exfiltration



Real-World Nigerian Scenario — Interswitch-Style Payment Platform

SCENARIO:

A Nigerian payment processing company — modelled on Interswitch's architecture — onboards a new engineering team of 12 developers across three functions: backend, DevOps, and security. The CTO must implement AWS IAM security controls that enforce MFA, apply least privilege, and prevent the DevOps team from accidentally granting themselves production access. The CISO has 30 days to demonstrate CBN compliance.



Implementation Plan — What the Security Engineer Builds

Step 1: Root Account Hardening

Delete root access keys (found during audit — a developer had created them 6 months prior). Enable FIDO2 security key on root account. Store root credentials in company password vault with dual-person access requirement. Create dedicated IAM admin user for all administrative operations. Enable billing alerts on root.

Step 2: MFA Enforcement Policy

Create IAM group "AllUsers". Attach the MFA Enforcement Policy (DenyWithoutMFA) to the group. Add all 12 developers to the group. Result: every developer must enrol MFA within 30 minutes of their first login — they can only access iam:EnableMFADevice and iam:CreateVirtualMFADevice until they do. Set up 1Password Teams for corporate TOTP management.

Step 3: Least Privilege + Permission Boundaries for DevOps

Create separate IAM groups: BackendDev (s3:*, lambda:*, dynamodb:*), DevOps (ec2:*, ecs:*, ecr:*, cloudformation:*), Security (cloudtrail:*, guardduty:*, securityhub:*). For DevOps: attach a Permission Boundary that excludes iam:CreateRole without the boundary condition — preventing them from creating roles with wider permissions than their own boundary allows. This is the delegation-without-escalation pattern.

Step 4: CBN Compliance Audit

Download IAM Credential Report. Filter: mfa_active = false → 3 users found without MFA → notify and re-enforce. Run IAM Access Advisor on each group → BackendDev has ec2:* access never used (inherited from an old policy) → remove. Run Access Analyzer → finds one S3 bucket policy granting access to an external account (legacy partner integration) → review and archive if legitimate. Document everything for CBN audit trail.



Discussion: Why does the Permission Boundary on the DevOps team not affect the Security team's ability to configure CloudTrail? What would happen if an SCP at the OU level blocked iam:CreateRole?



Common Mistakes & Exam Traps

● These are the most common SAA-C03 exam errors on MFA & IAM Security — every one costs marks.



TRAP 1: MFA on root is NOT automatic — and root access keys are separate from MFA

The root account is created with no MFA. It must be manually enabled. More importantly: MFA and root access keys are two separate controls. You can have MFA enabled AND still have root access keys — the keys are not protected by MFA at the API level. The correct answer is always: delete root access keys AND enable MFA. One without the other is incomplete.



TRAP 2: Permission Boundaries do NOT grant permissions — they only restrict

A very common exam distractor. A Permission Boundary that allows s3:* does NOT mean the entity can access S3. The identity policy must ALSO have an explicit Allow for s3:*. Effective permissions = intersection of identity policy AND boundary. Boundary alone grants nothing. This is the same intersection principle as SCPs — the ceiling restricts, but the floor still requires an explicit IAM Allow.



TRAP 3: IAM Access Analyzer ≠ IAM Access Advisor — they do completely different things

Access Analyzer detects EXTERNAL resource access — it looks at resource-based policies to find resources accessible from outside your account. Access Advisor shows you per-user SERVICE USAGE HISTORY — which services a user has actually accessed. These are tested interchangeably in distractors. 'Identify unused permissions' → Access Advisor. 'Detect S3 bucket accessible from the internet' → Access Analyzer.



TRAP 4: SCPs apply to accounts; IAM policies apply to roles/users — they work at different layers

SCPs operate at the AWS Organizations level — they define the maximum permissions ceiling for entire accounts. IAM policies operate inside accounts — they define what a specific user or role can do. Both use the same intersection logic, but they operate independently at different layers. A question about restricting ALL users in an account from a specific action → SCP. A question about restricting a specific developer → IAM policy (or Permission Boundary).



TRAP 5: The IAM Credential Report shows MFA status but does NOT enforce anything

The Credential Report is a DETECTIVE control — it tells you the state of your credentials. It does not enforce MFA. It does not disable inactive keys. It does not rotate passwords. To enforce MFA, you need the IAM Deny policy with aws:MultiFactorAuthPresent condition. To auto-disable inactive keys, you need a Lambda function triggered on a schedule. The Credential Report is the observation tool — enforcement requires separate controls.



Question

A security engineer at a Lagos fintech is setting up AWS for a team of 20 developers. The engineer needs to ensure that: (1) all developers are required to use MFA, (2) a junior developer can create IAM roles for their Lambda functions but cannot create roles with more permissions than their own, and (3) the security team can identify which developers have not used their S3 permissions in the past 90 days. Which combination of THREE configurations meets ALL requirements?

- A** Attach an IAM policy with Effect:Deny, Condition: `aws:MultiFactorAuthPresent=false`, NotAction: `[iam:CreateVirtualMFADevice, iam:EnableMFADevice]` to the Developers IAM group.
- B** Attach an IAM Permission Boundary to the junior developer's IAM user that limits the maximum permissions to what the junior developer currently has. Require the boundary to be attached to any role they create.
- C** Enable MFA on the root account and require all developers to use the root account credentials with MFA for all operations.
- D** Use IAM Access Advisor on each developer's user or role to review last-accessed service dates and identify permissions for S3 that have not been used in 90 days.
- E** Run the IAM Credential Report monthly, filter for `mfa_active=false`, and use IAM Access Analyzer to flag any S3 buckets accessible by the developers from outside the account.



Question

A security engineer at a Lagos fintech is setting up AWS for a team of 20 developers. The engineer needs to ensure that: (1) all developers are required to use MFA, (2) a junior developer can create IAM roles for their Lambda functions but cannot create roles with more permissions than their own, and (3) the security team can identify which developers have not used their S3 permissions in the past 90 days. Which combination of THREE configurations meets ALL requirements?

A

Attach an IAM policy with Effect:Deny, Condition: aws:MultiFactorAuthPresent=false, NotAction: [iam:CreateVirtualMFADevice, iam:EnableMFADevice] to the Developers IAM group.

✓ CORRECT

Correct. This is the standard MFA enforcement pattern. DenyWithoutMFA on the group with NotAction exceptions allows users to enrol MFA before any other action works.

B

Attach an IAM Permission Boundary to the junior developer's IAM user that limits the maximum permissions to what the junior developer currently has. Require the boundary to be attached to any role they create.

✓ CORRECT

Correct. This implements delegation-without-escalation. The junior developer can create Lambda execution roles, but none can exceed the boundary's scope.

C

Enable MFA on the root account and require all developers to use the root account credentials with MFA for all operations.

Wrong on two counts. Root credentials should never be shared. All-team root usage is a major security anti-pattern — it eliminates individual accountability and cannot be restricted by IAM policies.

D

Use IAM Access Advisor on each developer's user or role to review last-accessed service dates and identify permissions for S3 that have not been used in 90 days.

✓ CORRECT

Correct. Access Advisor shows per-user service usage history. Filtering for S3 last access > 90 days identifies unused S3 permissions for removal — the operational tool for least-privilege maintenance.

E

Run the IAM Credential Report monthly, filter for mfa_active=false, and use IAM Access Analyzer to flag any S3 buckets accessible by the developers from outside the account.

Partially correct but does not meet the requirement. The Credential Report detects non-MFA users but does not enforce MFA. Access Analyzer detects external access, not internal unused permissions.

Key Takeaways — What You Learned Today

MFA & Security Best Practices

Concepts Covered

- ✓ MFA types: Virtual (TOTP app), Hardware token, FIDO2/WebAuthn security key
- ✓ FIDO2 is phishing-resistant — TOTP codes can be intercepted; FIDO2 cannot
- ✓ Root account: delete access keys + enable FIDO2 MFA, never use for daily work
- ✓ MFA enforcement: IAM Deny policy with `aws:MultiFactorAuthPresent=false`
- ✓ 8 IAM security best practices — root, keys, MFA, PoLP, roles, rotation, boundaries, analyzer
- ✓ Permission Boundaries: ceiling for delegated role creation — intersection rule applies
- ✓ IAM Access Analyzer: detect external resource access (S3, roles, KMS, Lambda)
- ✓ IAM Credential Report: compliance snapshot — MFA status, key ages, last-used dates
- ✓ IAM Access Advisor: per-user service usage — tool for removing unused permissions
- ✓ Layered defence: Root → MFA → Least Privilege → Monitoring (each layer assumes breach of the one above)

Before Next Class

1. Review all concepts without notes — close this and recall from memory
2. Console lab: enable MFA on your IAM user, attach the `DenyWithoutMFA` policy, confirm it works by testing access without MFA
3. Download your IAM Credential Report — check every user's `mfa_active` status
4. Run IAM Access Advisor on your own user — identify any services you've never accessed
5. Enable IAM Access Analyzer for your account — check for any external access findings
6. Write out the 5 exam traps by hand — especially the Access Analyzer vs Access Advisor distinction
7. Post your Credential Report screenshot (redact names) on the WhatsApp group



Further Resources & Reading

Go deeper with these official AWS and industry resources:



AWS IAM Best Practices — Official Documentation

OFFICIAL DOCS

<https://docs.aws.amazon.com/IAM/latest/UserGuide/best-practices.html>

AWS's own best-practice guide: root protection, least privilege, MFA, access keys, roles over users. This is the authoritative checklist. Read it cover to cover — many SAA-C03 questions are drawn directly from it.



AWS Security Hub — Foundational Security Best Practices Standard

COMPLIANCE

<https://docs.aws.amazon.com/securityhub/latest/userguide/fsbp-standard.html>

Automated compliance checks against AWS security best practices, including specific IAM controls: root MFA, hardware MFA, unused credentials, access key rotation, and IAM password policy. Enabling this gives you a scored compliance dashboard against all controls in this lesson.



IAM Access Analyzer — User Guide

TOOL REFERENCE

<https://docs.aws.amazon.com/IAM/latest/UserGuide/what-is-access-analyzer.html>

Complete guide to IAM Access Analyzer: how findings are generated, how to resolve them, how to use Access Analyzer to generate least-privilege policies from CloudTrail activity (a powerful automated PoLP implementation tool).



IAM Credential Report — How to Generate & Interpret

OPERATIONAL

https://docs.aws.amazon.com/IAM/latest/UserGuide/id_credentials_getting-report.html

Step-by-step guide to generating the Credential Report via console and CLI, with a full field reference. Learn to automate monthly credential audits using Lambda + S3 for long-term compliance history.



SAA-C03 Exam Guide — Domain 2: Design Secure Architectures

EXAM PREP

https://d1.awsstatic.com/training-and-certification/docs-sa-assoc/AWS-Certified-Solutions-Architect-Associate_Exam-Guide.pdf

Domain 2 directly covers IAM, MFA, Permission Boundaries, SCPs, and Access Analyzer. Read the task statement for 2.1 (Implement security controls) carefully — it maps exactly to this lesson's content.



Homework: Read at least ONE resource above before next class. Post what you learned on the WhatsApp group.



Week 2 · Day 5 Complete

MFA & Security Best Practices

IAM & Security

Next: Hands-on Console Lab →

basestack.academy · Cohort 1 · AWS Cloud Accelerator